Practical Report

Reconnaissance & Enumeration

Intern: Sabir Ali

Academy: IqraSec Academy

Scope: One combined report for the three related TryHackMe rooms under Reconnaissance & Enumeration.

Room 1: Passive Reconnaissance

1. Objective

To understand how to gather information about a target from publicly available sources without directly probing the target systems.

2. Concepts and Understanding

- **Passive vs. active reconnaissance:** Passive reconnaissance uses public information sources and does not directly interact with the target. Direct probes such as pinging or connecting to target ports are active reconnaissance.
- **WHOIS and RDAP:** These provide domain registration details such as registrar, registration dates, status, and name servers. RDAP is the modern, structured-JSON successor to the traditional WHOIS service.
- **DNS records:** A, AAAA, CNAME, MX, SOA, and TXT records help identify addresses, aliases, mail services, authoritative DNS information, and domain verification or email-security data.
- **Passive subdomain discovery:** DNSDumpster aggregates publicly available DNS information, while Certificate Transparency logs searched through crt.sh can reveal domain names included in TLS certificates.
- **Internet-exposed services:** Shodan indexes information collected from internet-connected devices, including open ports, service banners, and hosting details.

3. Practical Work

I completed the room exercises by reviewing domain registration information with WHOIS/RDAP, querying DNS records with nslookup and dig, exploring DNSDumpster and Certificate Transparency logs for subdomain information, and examining Shodan results to understand how exposed services are indexed.

4. Tools and Resources Used

- WHOIS and RDAP lookup (RDAP queried with curl; jq used to format JSON output).
- nslookup and dig for DNS record queries.
- DNSDumpster for public DNS and subdomain information.
- crt.sh for Certificate Transparency log searches.
- Shodan for indexed internet-facing hosts, ports, and service banners.
- TryHackMe AttackBox / Linux terminal and a web browser.

Note: *The room treats these lookups as passive because they rely on public sources or public DNS resolvers rather than directly probing the target services.*

5. Evidence and Screenshots

There are so me relevant screenshot and evidence.

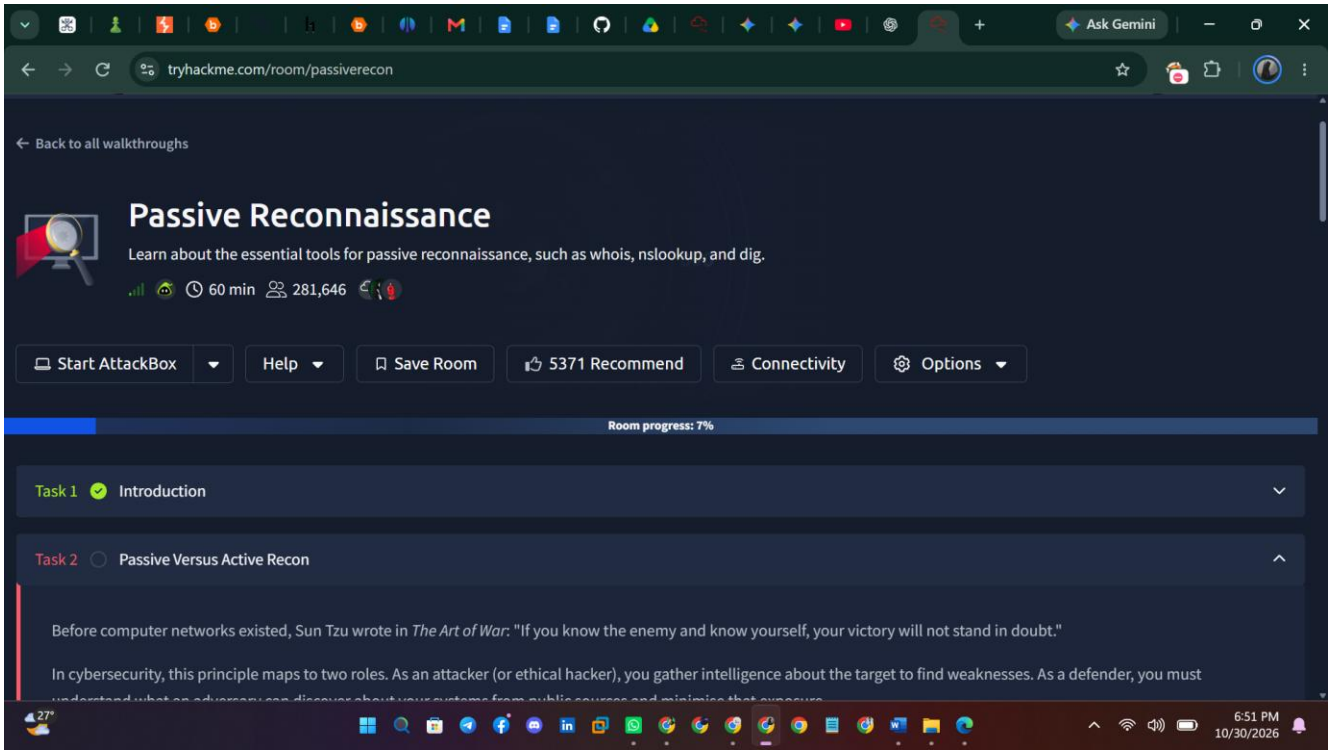


Figure 1: Join Room and Read Introduction about it

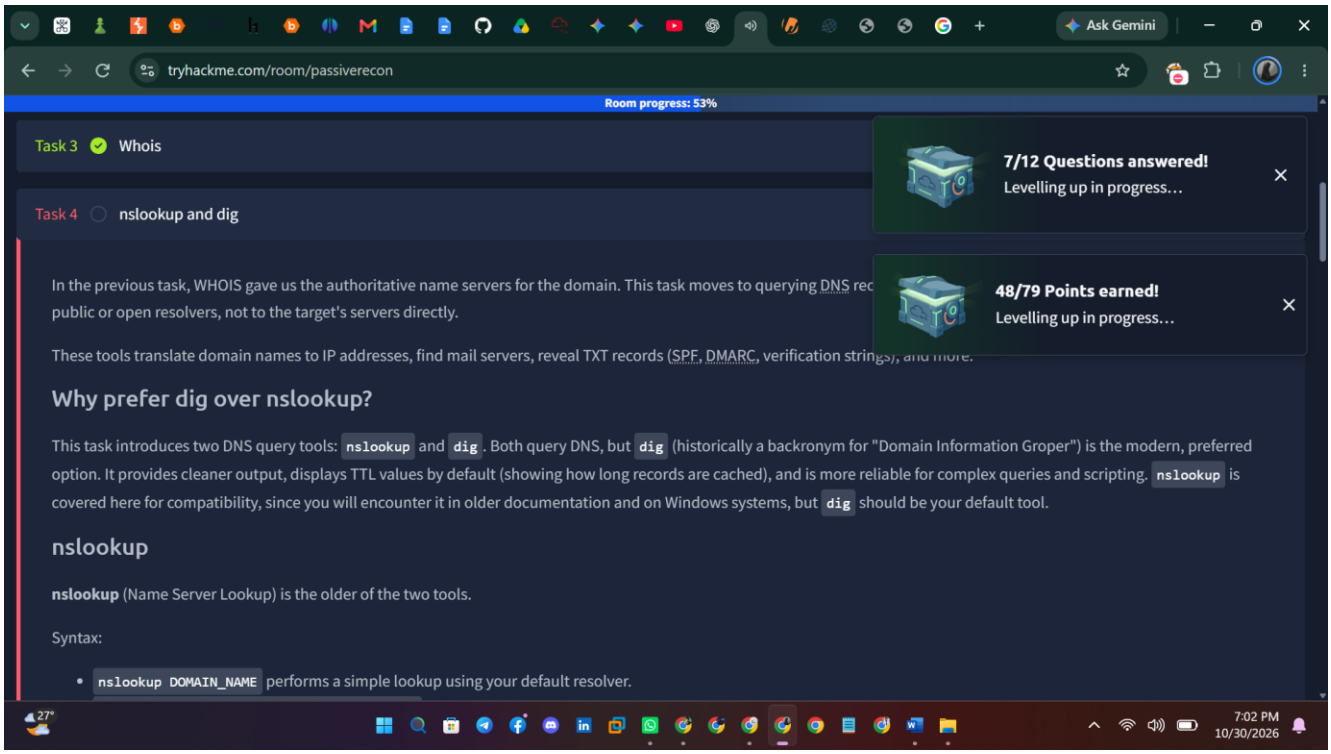


Figure 2: Explore nslookup and dig in details

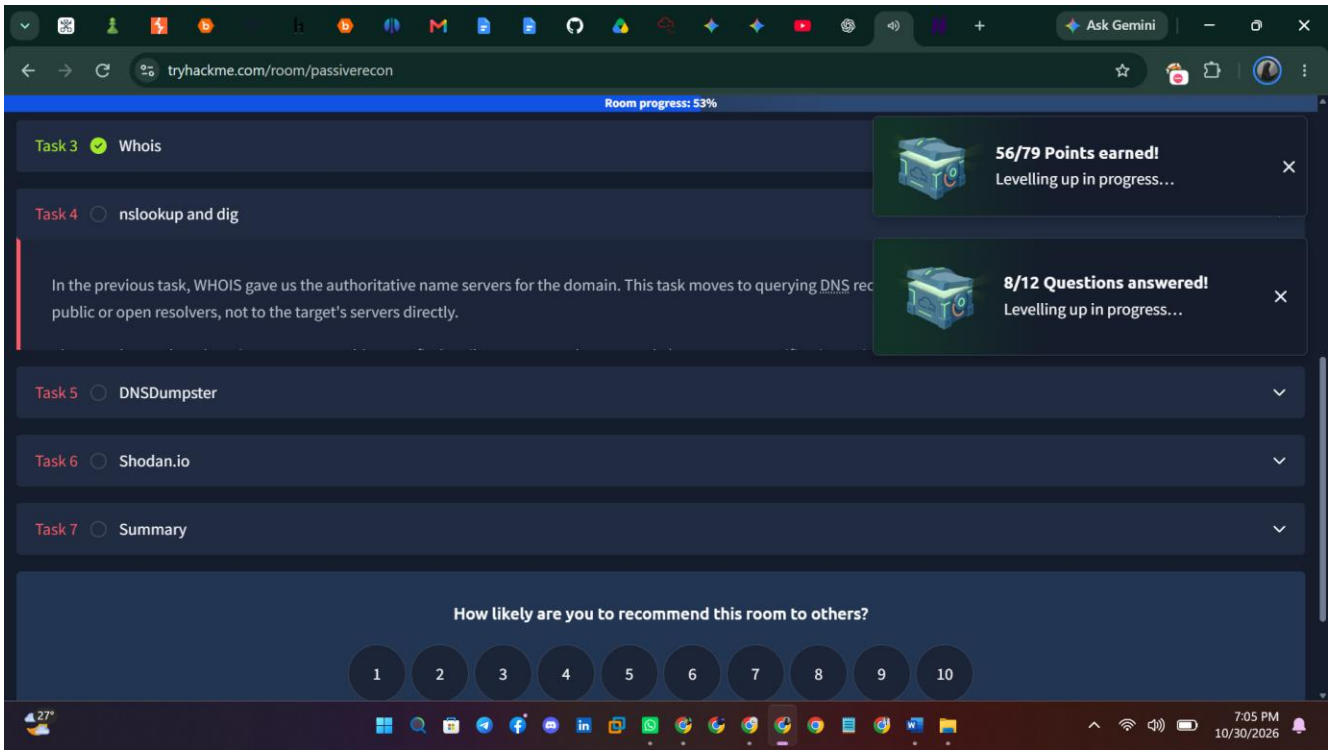


Figure 3: Lean how to recon through **Whois**

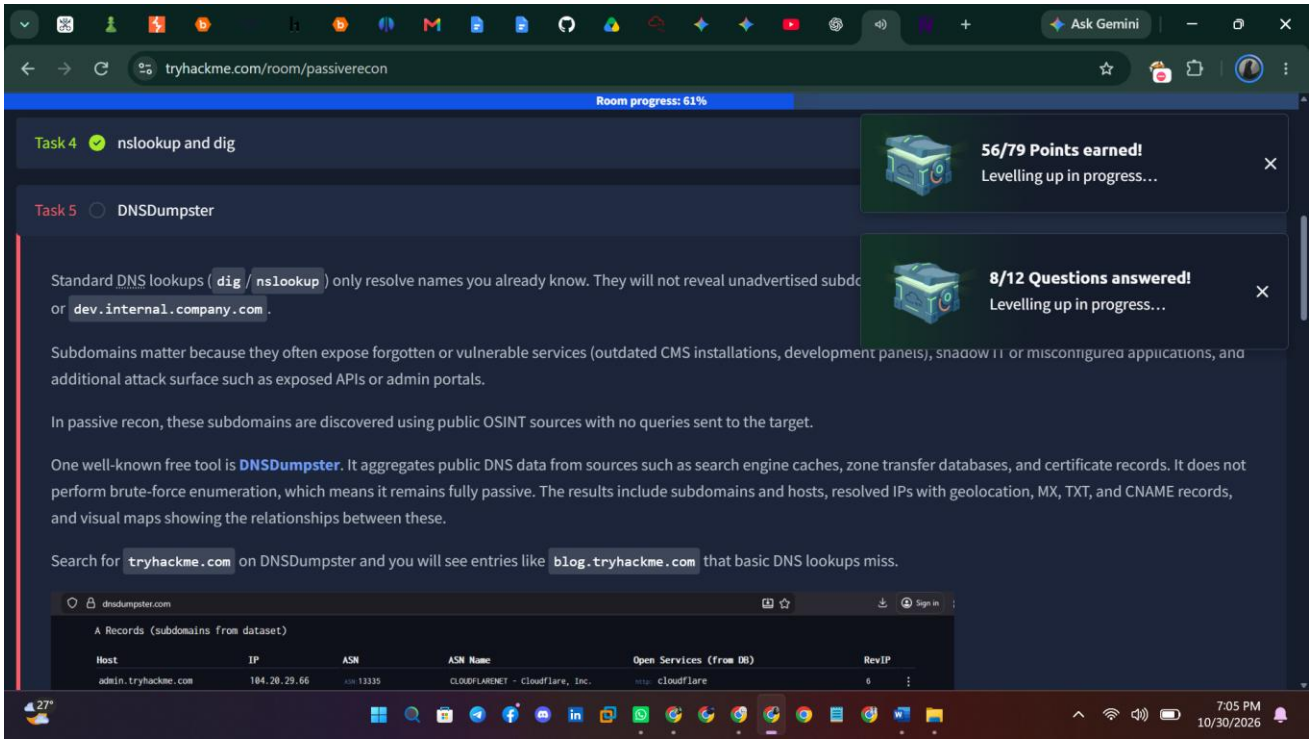


Figure 4: DNS Dumpster in details learning

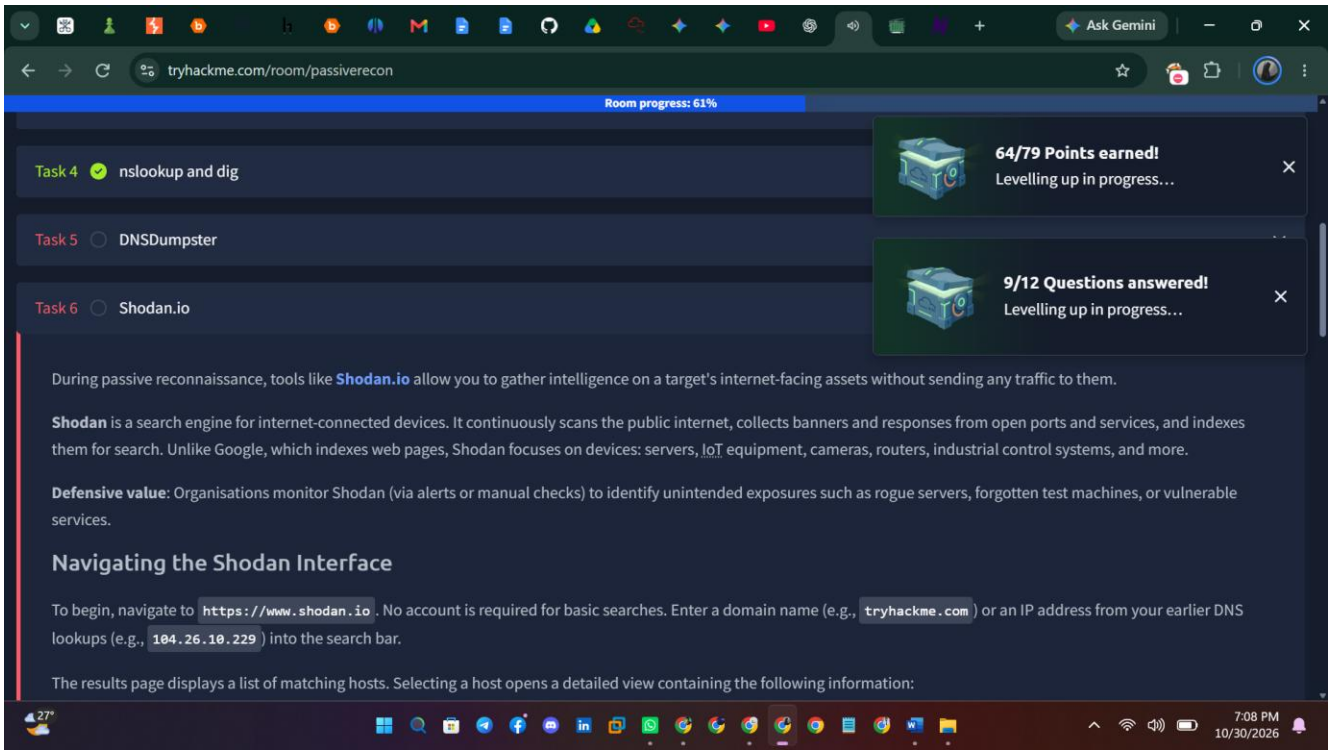


Figure 5: Explore Shodan.io and learn in details

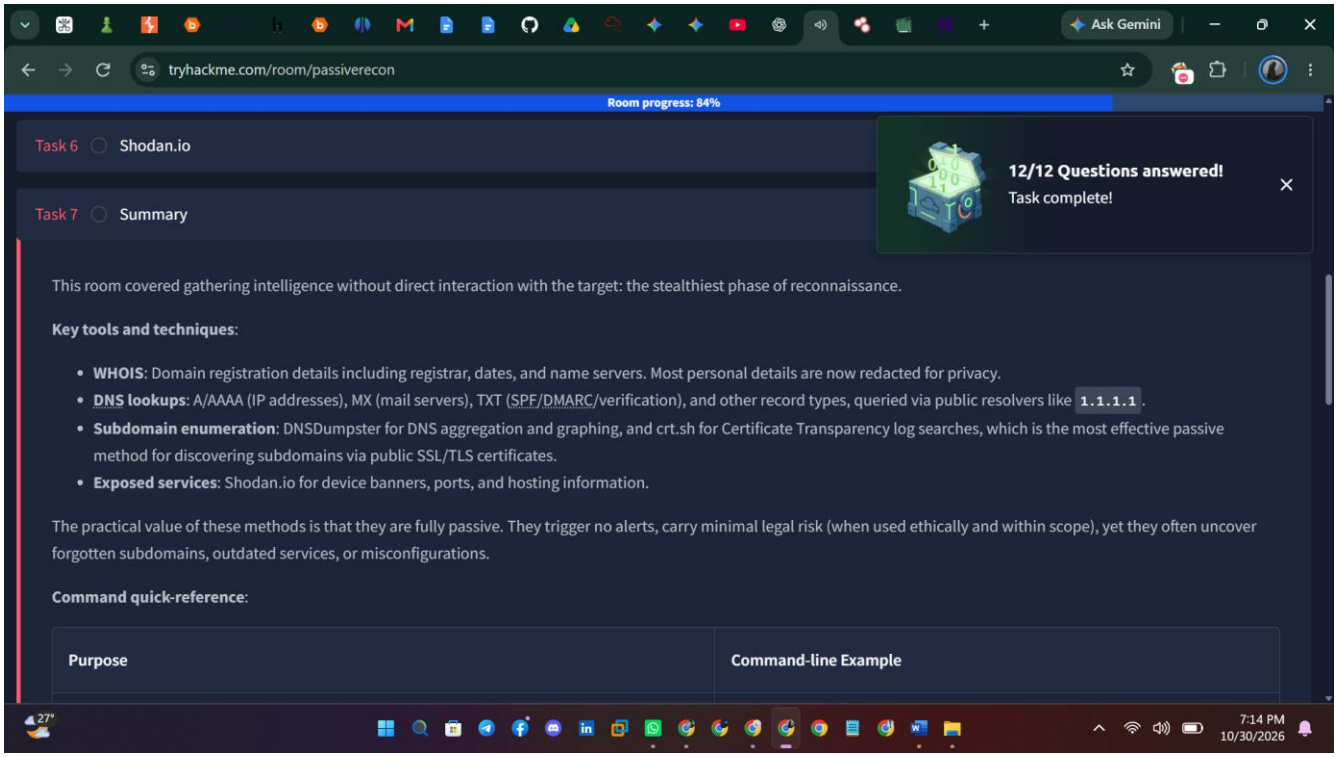


Figure 6: Revise all concepts and additional information



Figure 7: Complete all task of the room and solve the room

6. Result

I developed a practical understanding of how domain registration records, DNS information, certificate logs, and internet-wide service indexes can help build an initial picture of a target before direct testing.

7. Key Learnings

- Passive reconnaissance can reveal useful information without directly probing target services.
- DNS records and certificate logs can help identify related domains and subdomains.
- RDAP provides structured data, while WHOIS remains a familiar legacy lookup method.
- Shodan results are based on its own collected data and should be verified before drawing conclusions.

Room 2: Active Reconnaissance

1. Objective

To understand how direct interaction with a target system or network can reveal host availability, network paths, running services, and basic service information.

2. Concepts and Understanding

- **Browser-based reconnaissance:** Browser Developer Tools can inspect network requests, response headers, JavaScript and source files, cookies, browser storage, and TLS certificate details.
- **Ping and ICMP:** Ping sends ICMP Echo Requests to check reachability and measure response time and packet loss. TTL values can provide an operating-system clue, but they are not definitive.
- **Traceroute and MTR:** Traceroute uses increasing TTL values to identify network hops. MTR combines route tracing with repeated latency and packet-loss information.
- **Banner grabbing:** Telnet and Netcat can connect to TCP services and display banners that may reveal the service name and version.
- **TCP/UDP and secure communication:** Netcat supports client and listening modes and can work with TCP or UDP. Telnet sends data in clear text, so SSH is preferred for secure remote administration.

3. Practical Work

I completed the room exercises by inspecting website information through browser Developer Tools, checking host reachability with ping, tracing network paths with traceroute and MTR, and using Telnet and Netcat to connect to services and examine their responses. I also reviewed how browser extensions can assist technology identification and traffic routing.

4. Tools and Resources Used

- Firefox or another web browser with Developer Tools (Network, Sources, Application/Storage, and Security tabs).
- FoxyProxy and User-Agent Switcher and Manager for browser traffic and User-Agent configuration.
- Wappalyzer for website technology identification.
- ping for ICMP reachability checks and TTL observations.
- traceroute and mtr for network path and hop analysis.
- telnet and Netcat (nc) for TCP connections and banner grabbing.

5. Evidence and Screenshots

There are so me relevant screenshot and evidence.

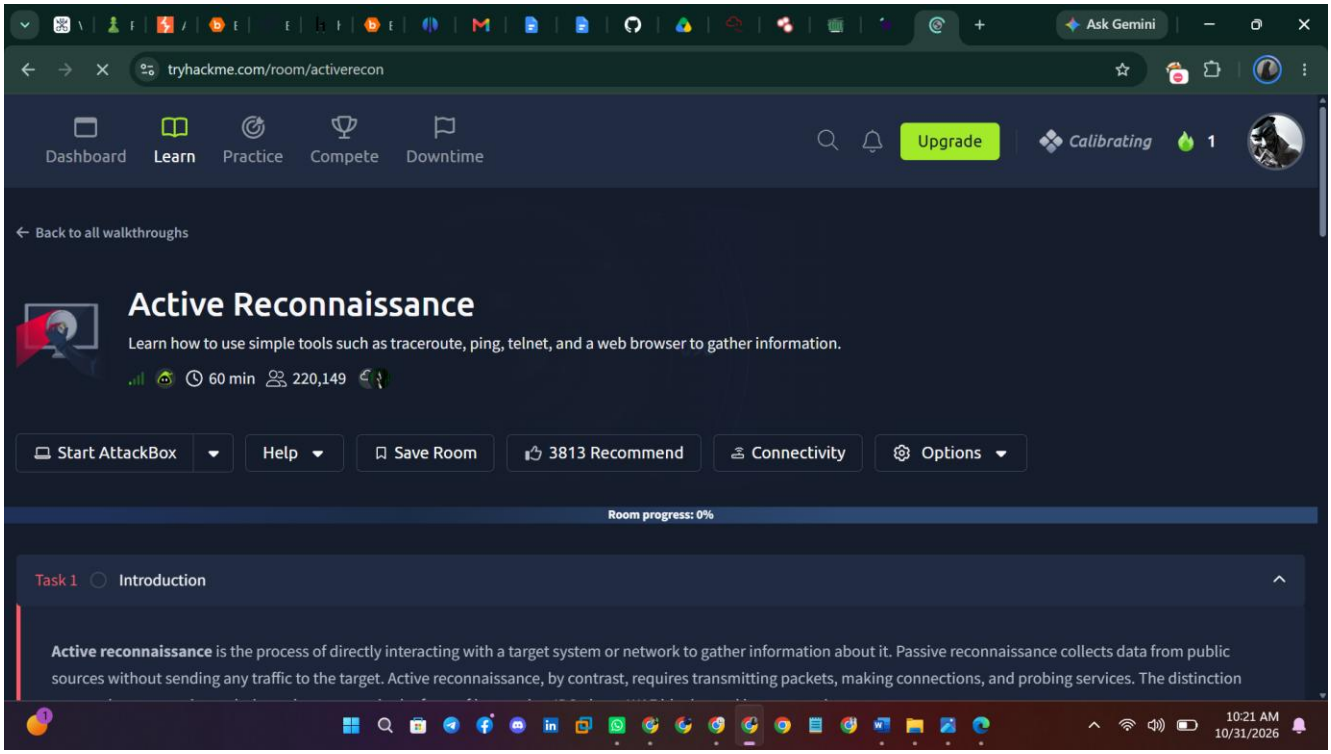


Figure 1: Join Room for active recon

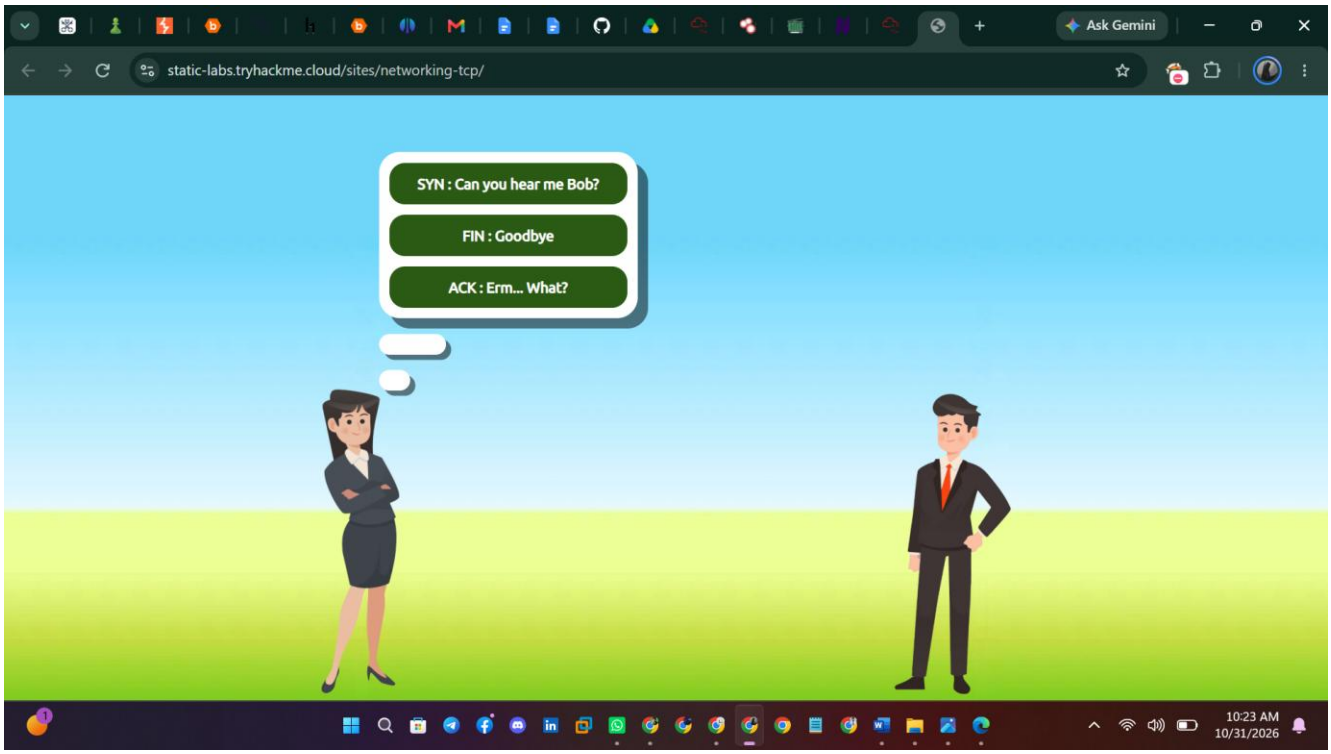


Figure 2: Task no.1 of this room

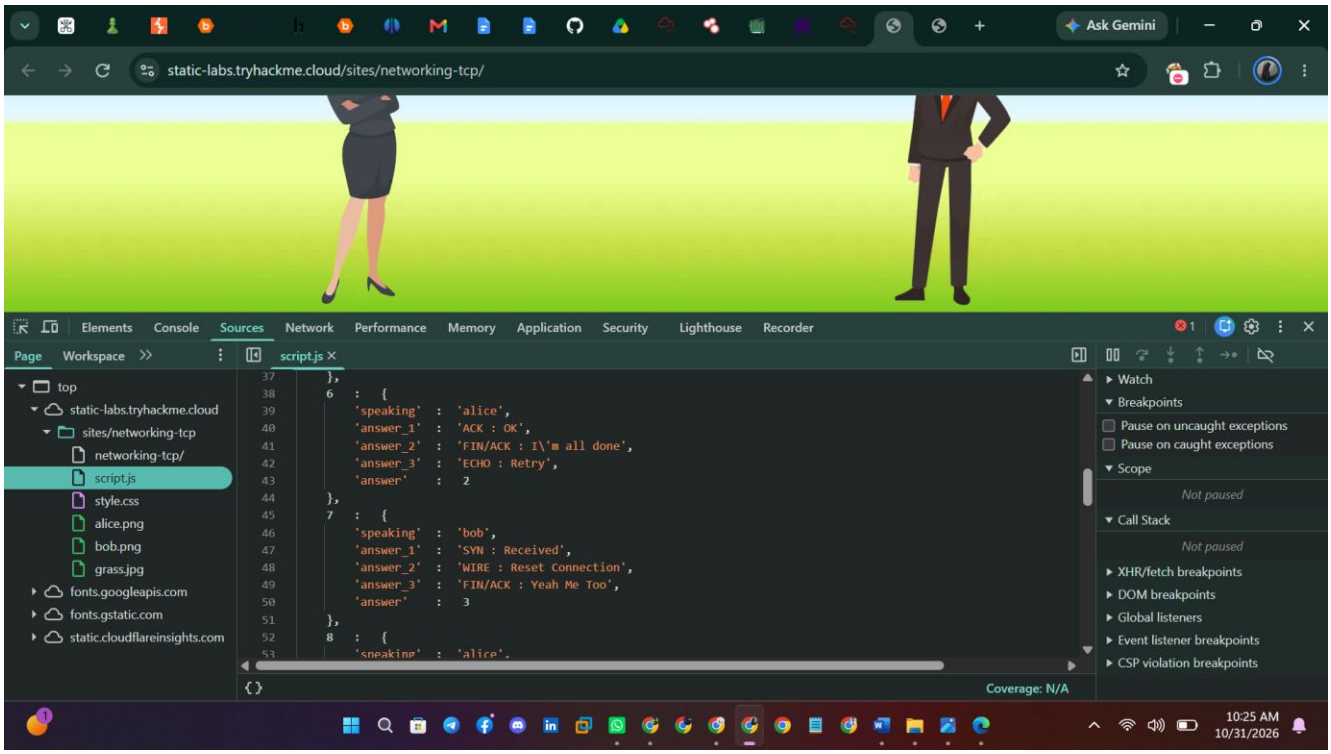


Figure 3: Open Inspect and get the Answer of the room task

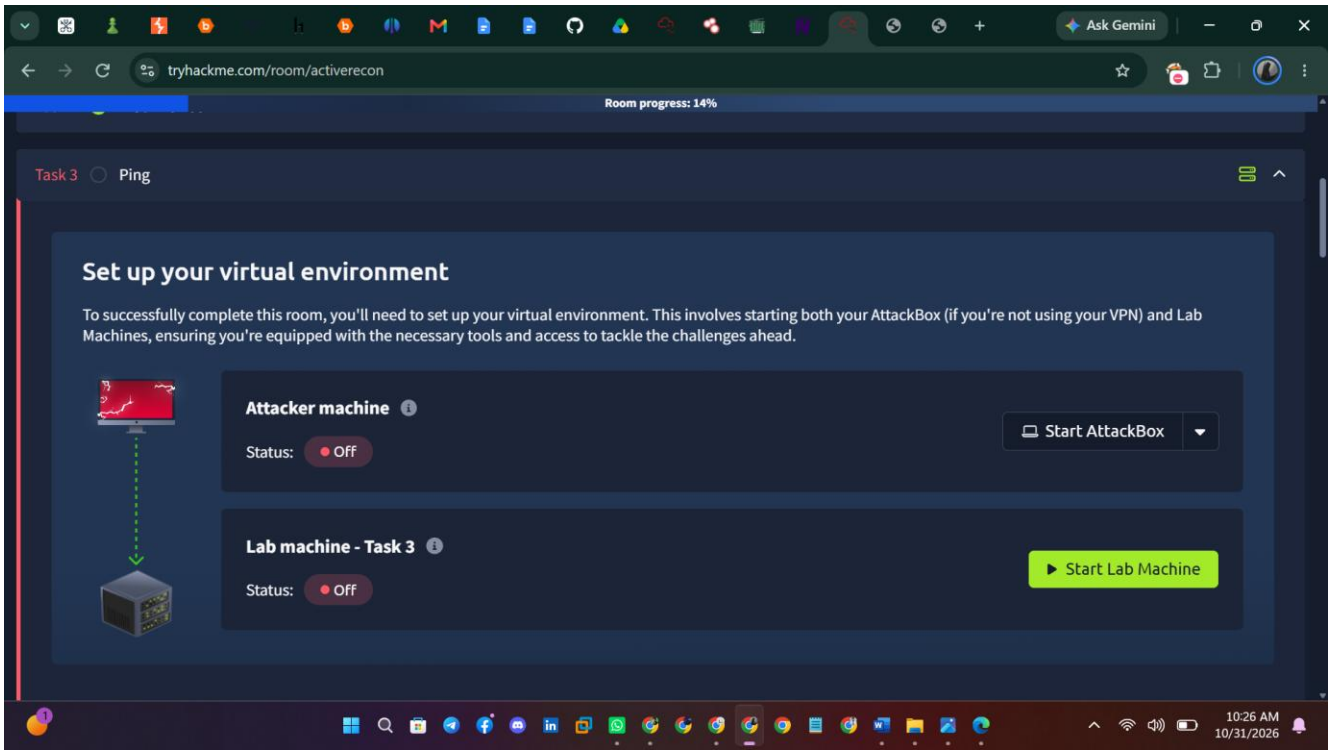


Figure 4: Start Lab machine to solve all practical labs in this room

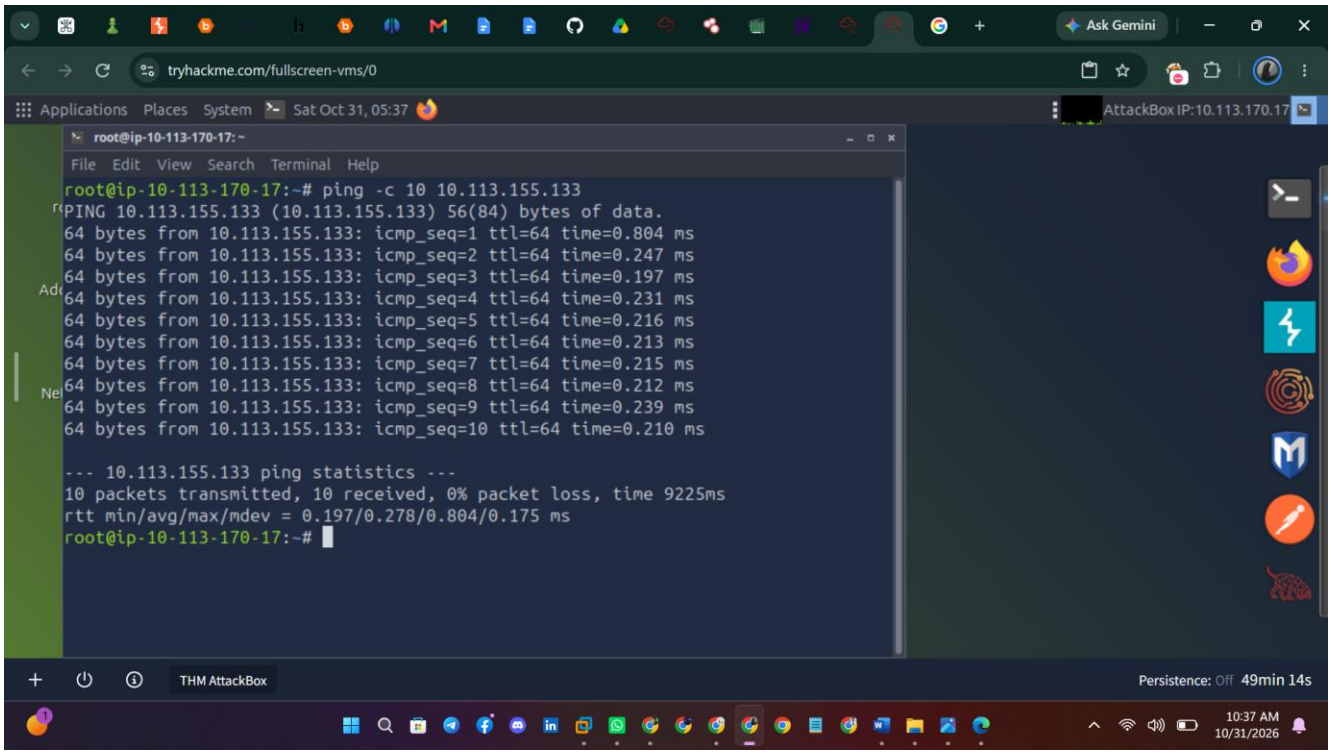


Figure 5: Ping on the Lab machine for get answer of the task

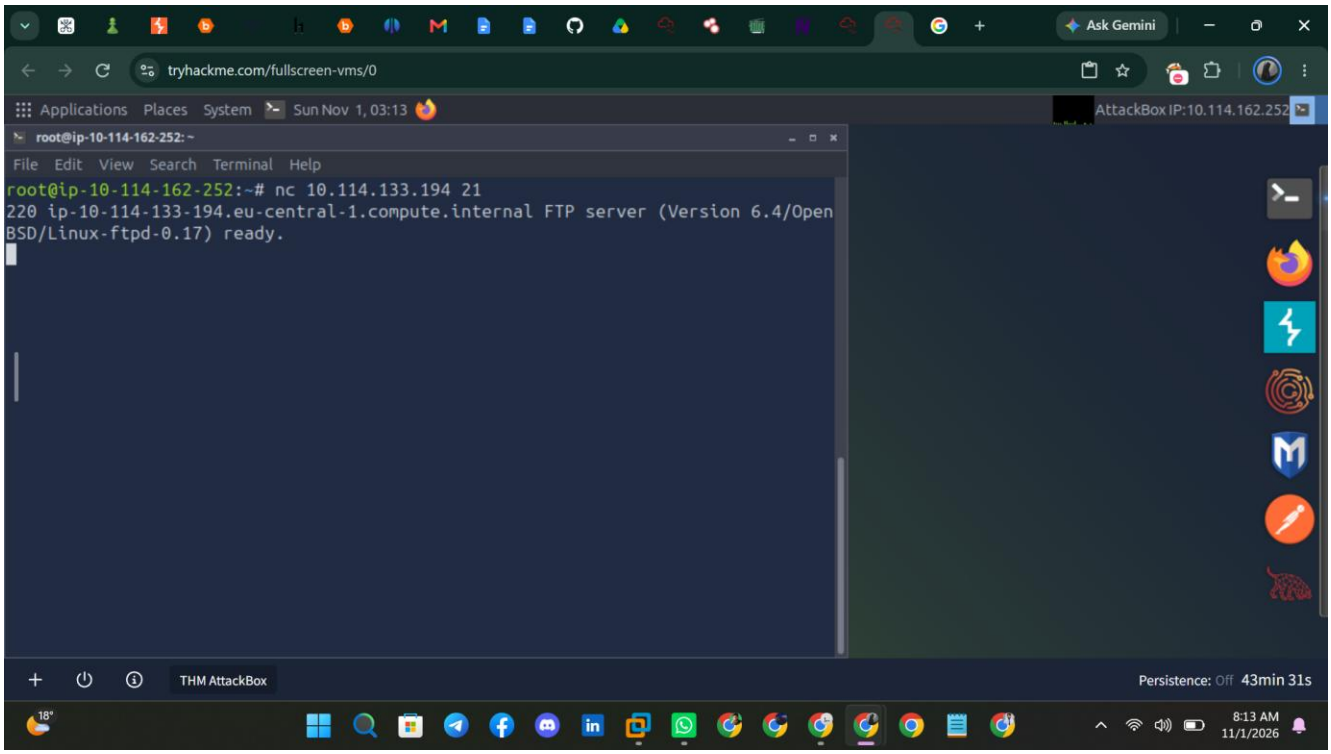


Figure 6: Listening through Netcat and solve the task in attack box



Figure 7: Complete all the task of that room and solve the room

6. Result

I gained practical experience with basic active reconnaissance techniques and learned how direct network interaction can provide information that public-source research alone may not reveal.

7. Key Learnings

- A successful ping confirms an ICMP response; no reply does not always mean that a host is offline.
- TTL can provide a clue about the originating operating system, but network hops change the observed value.
- Traceroute paths may vary because of routing, load balancing, or filtering.
- Telnet is useful for understanding clear-text banner grabbing, while Netcat offers more flexible connection and listening options.

Room 3: Content Discovery

1. Objective

To learn how to find website content that is not immediately visible or linked, using manual checks, OSINT resources, and automated enumeration.

2. Concepts and Understanding

- **Manual discovery:** Checking robots.txt, sitemap.xml, favicons, HTTP response headers, page source, and framework clues can reveal paths, technologies, and additional areas of an application.
- **OSINT-based discovery:** Google search operators, Wappalyzer, the Wayback Machine, GitHub repositories and commit history, and Amazon S3 bucket references can reveal publicly available information.
- **Automated discovery with Gobuster:** The dir mode searches for directories and files, dns mode tests possible subdomains, and vhost mode tests host names through the HTTP Host header.
- **Wordlists and response analysis:** SecLists provides candidate paths and names. HTTP status codes, redirects, and response lengths help interpret results and reduce false positives.
- **Subdomains and virtual hosts:** A subdomain is resolved through DNS, while a virtual host is selected by the web server using the HTTP Host header. They are related but not the same.

3. Practical Work

I completed the room exercises by inspecting common website files and page information, exploring search-engine operators and OSINT resources, and using Gobuster with wordlists for directory/file, DNS subdomain, and virtual-host discovery. I also followed the room instructions to configure the lab DNS resolver and hosts file for its local domain-resolution exercises.

4. Tools and Resources Used

- Web browser and cURL for manual website inspection and HTTP response information.
- Google search operators for targeted public-content searches.
- Wappalyzer, Wayback Machine, GitHub, and Amazon S3 references for OSINT-based discovery.
- Gobuster for directory/file, DNS subdomain, and virtual-host enumeration.
- SecLists wordlists, including Discovery/Web-Content and Discovery/DNS lists.
- Nano, dnsmasq configuration, and /etc/hosts for the room lab environment.

5. Evidence and Screenshots

There are so me relevant screenshot and evidence.

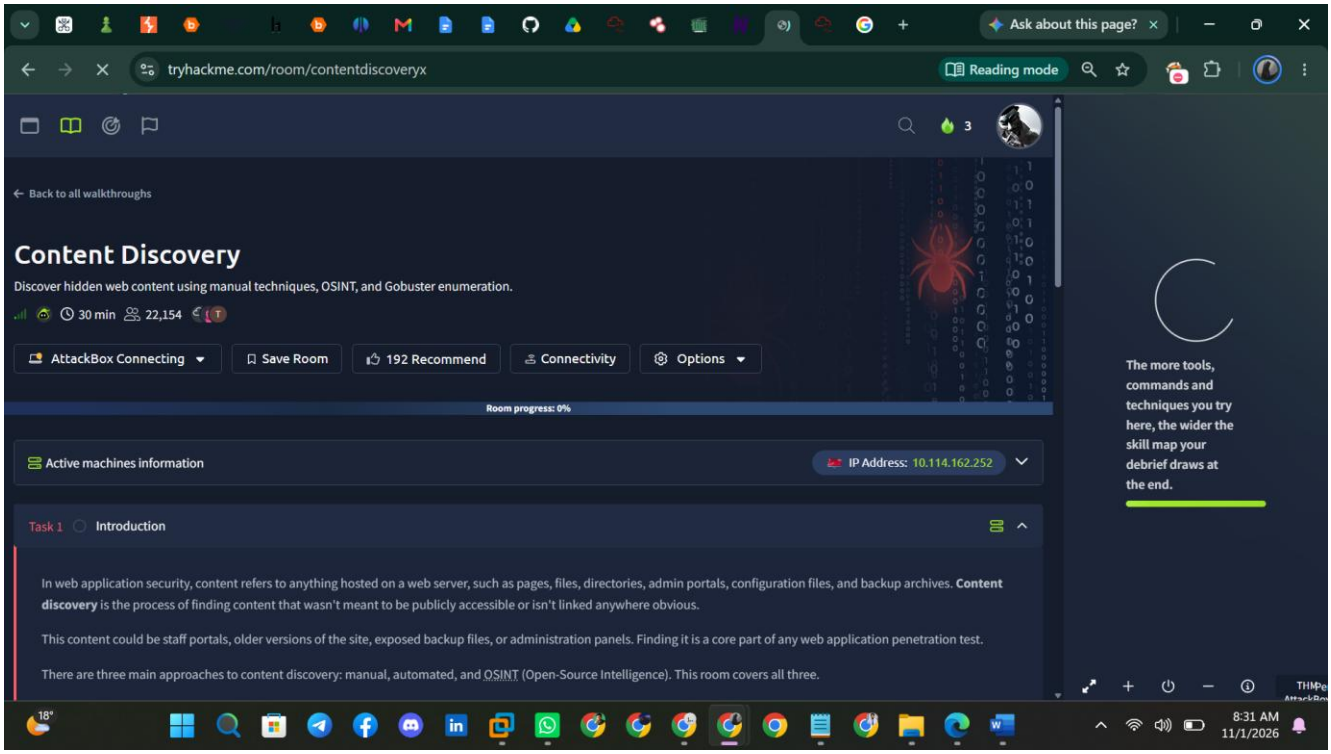


Figure 1: Join Room and explore its intro in detail

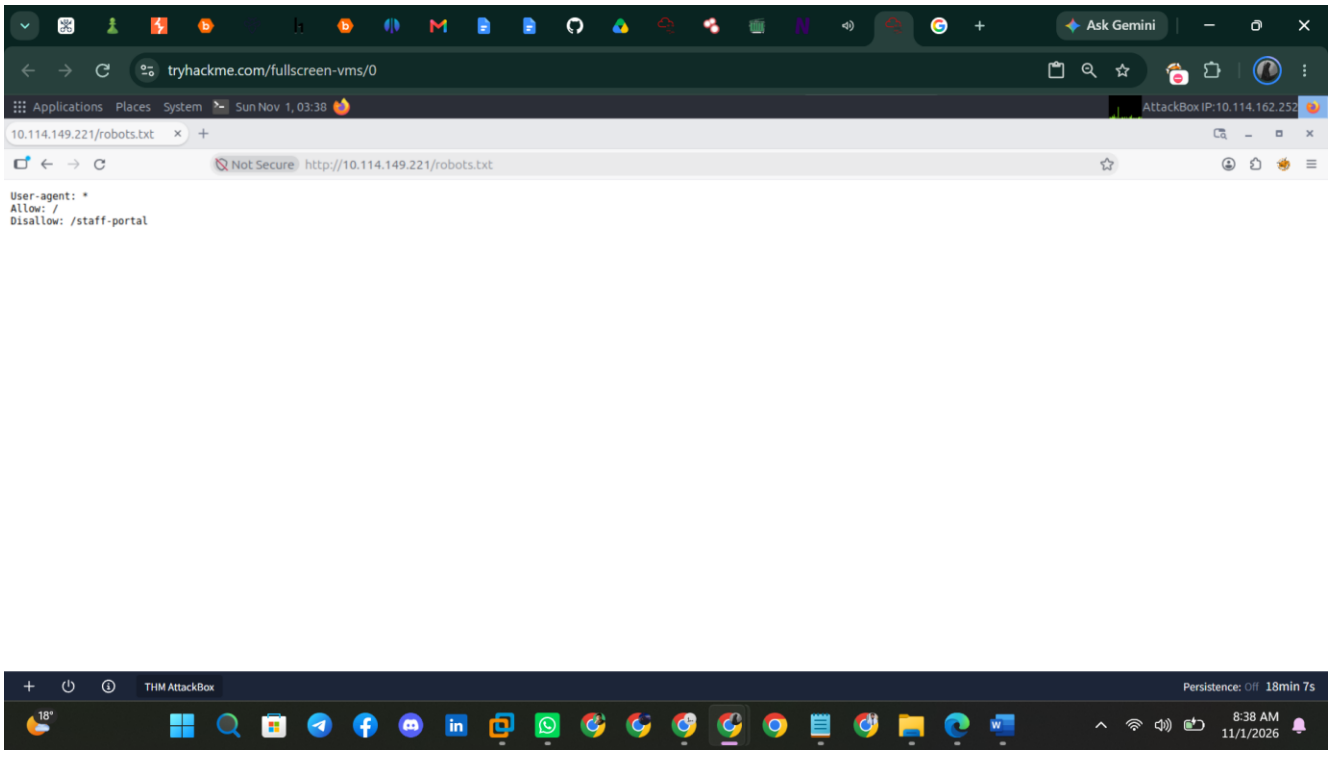


Figure 2: Task 1 Discover roborts.txt and find the answer that asked in room

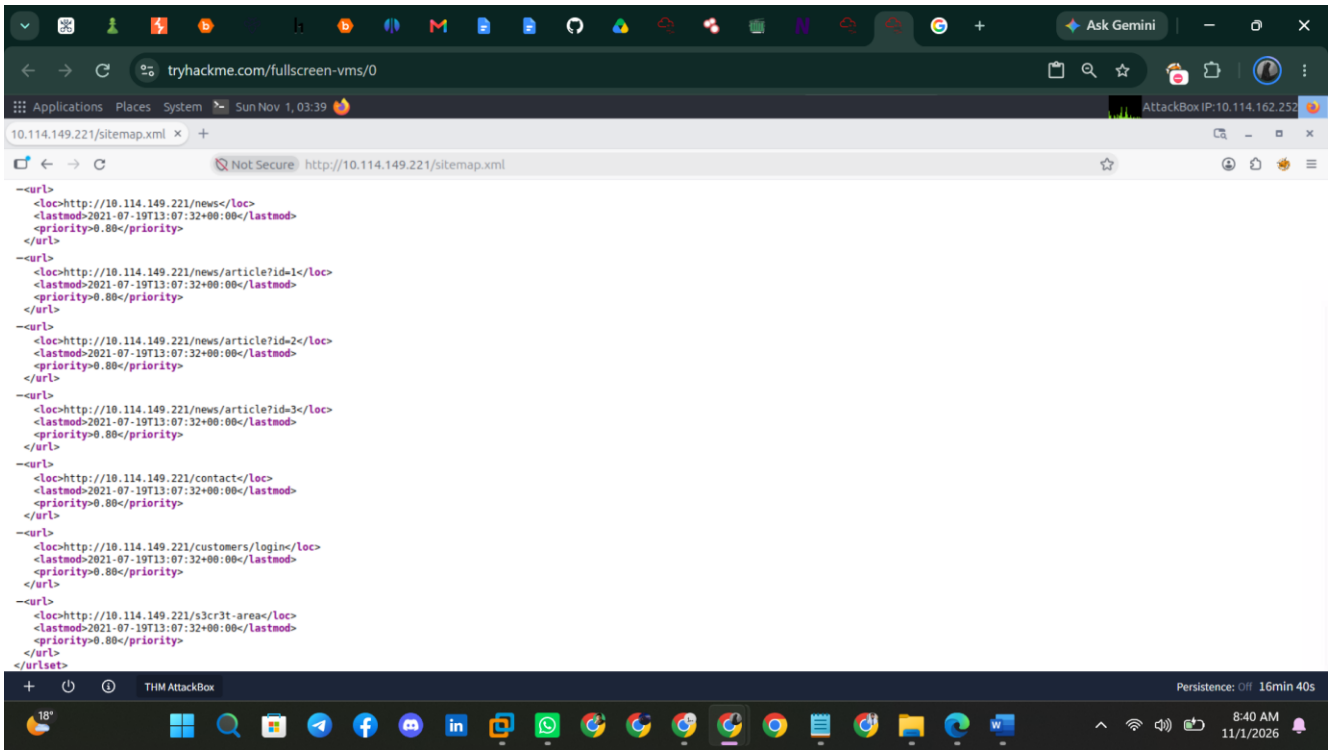


Figure 3: Task 2 to explore sitemap.xml

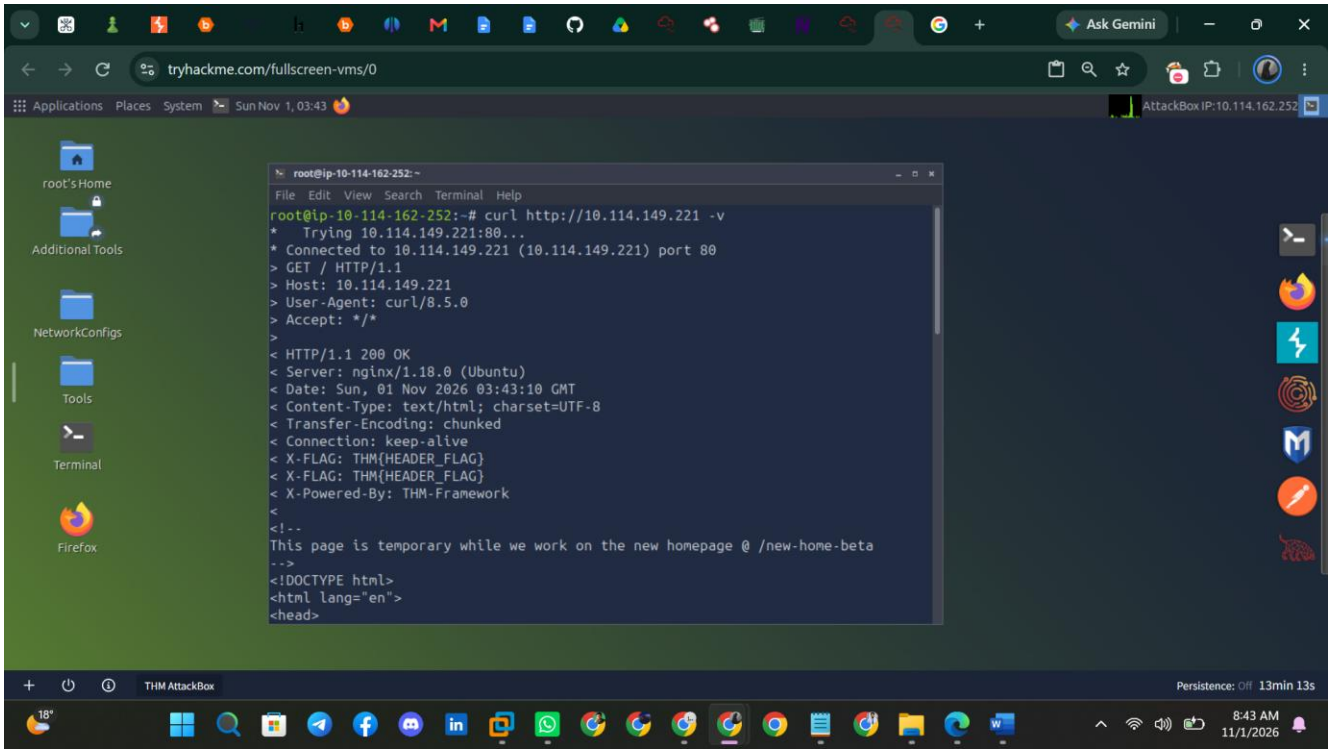


Figure 4: Use attack box to get question answer and solve the questions

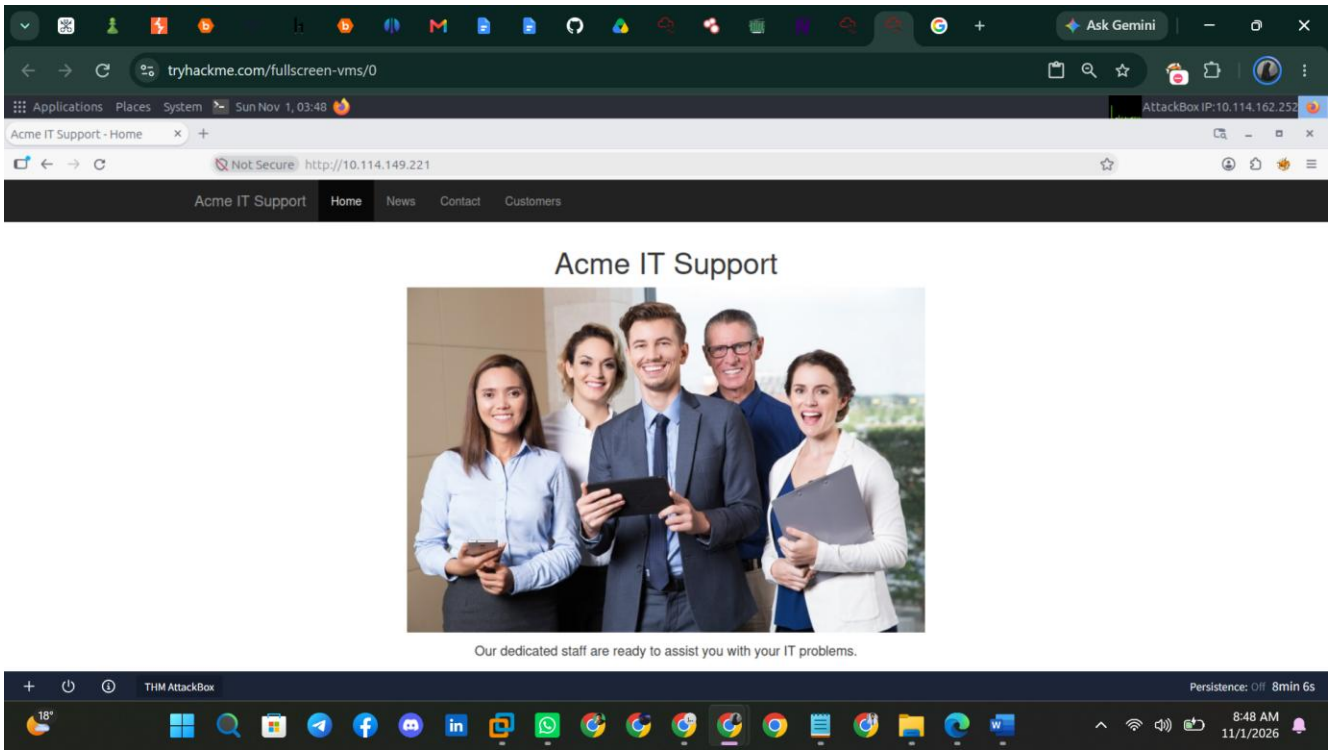


Figure 5: Host Machine running a website on port 80 for help to solve room questions

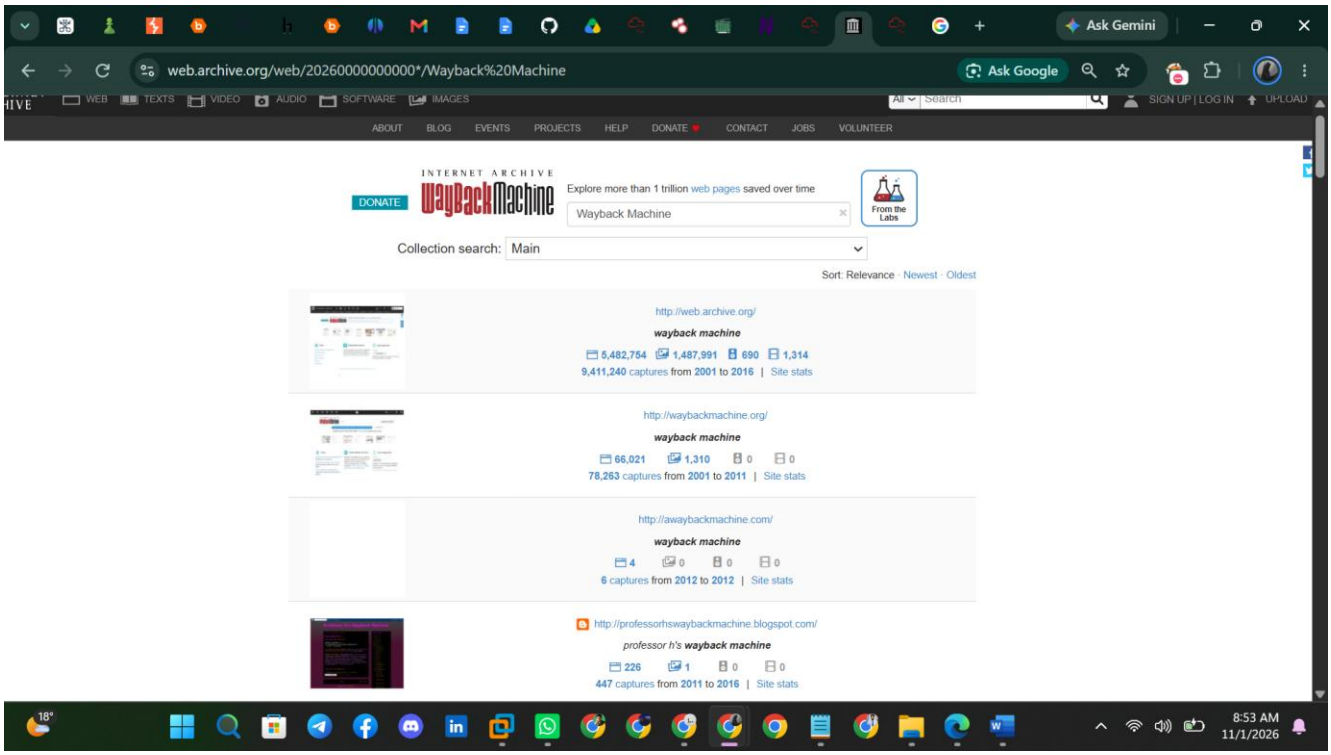


Figure 6: Solver practical task by using waybackmachine.com

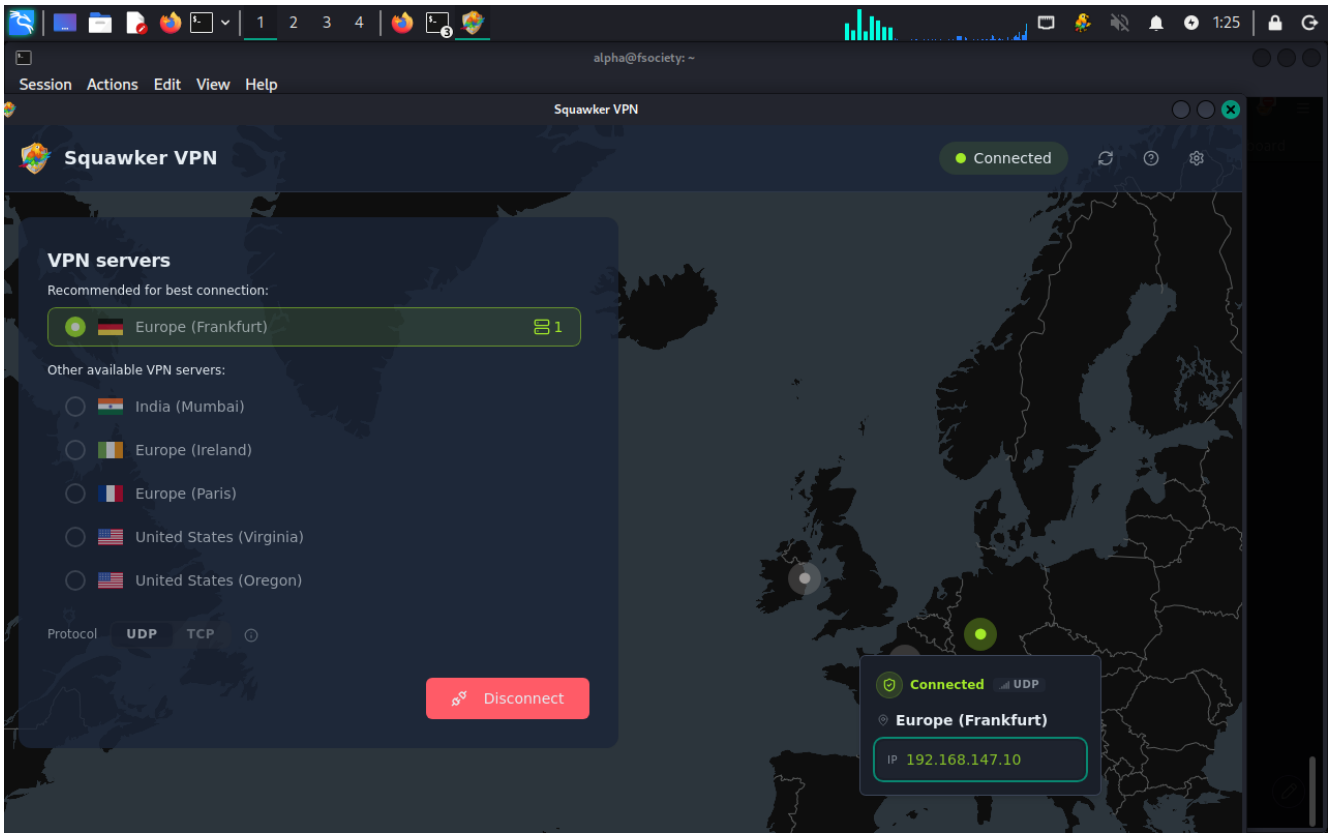


Figure 7: Connect my Tryhackme through the Squawker Vpn with my Kali Machine

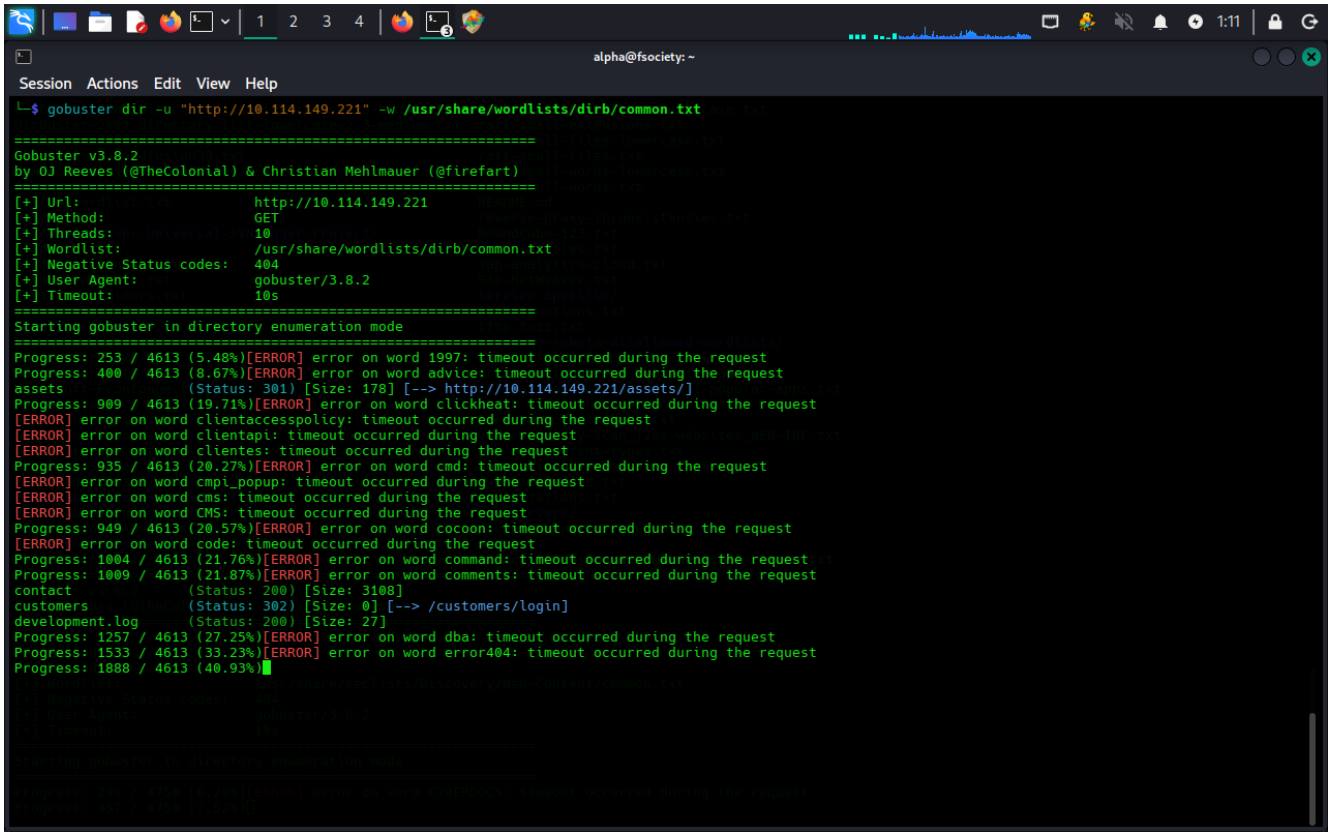


Figure 8: Run Gobuster tool in my kali to solve the room task

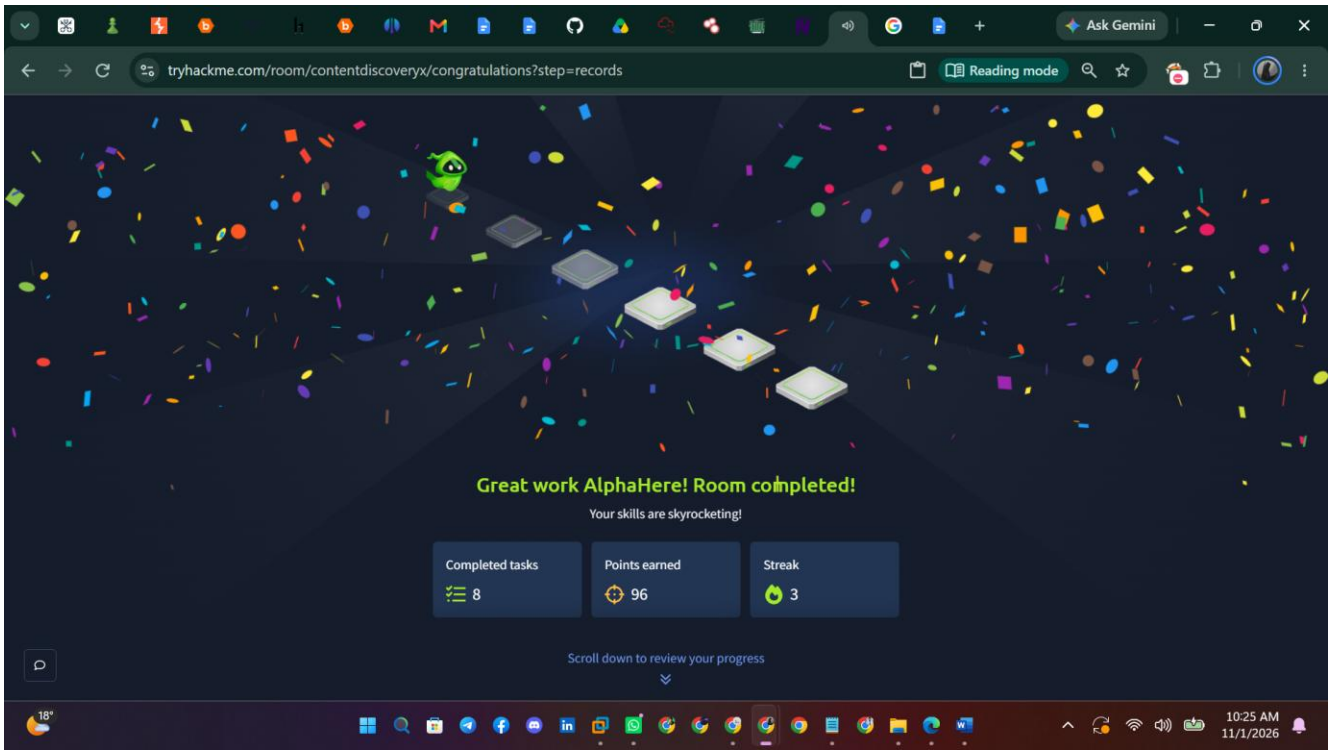


Figure 9: Complete all task and solve the room

6. Result

I learned how manual checks, OSINT resources, and automated enumeration can be combined to map a web application's visible and less obvious content, including directories, files, subdomains, and virtual hosts.

7. Key Learnings

- Manual checks can reveal useful paths and technical details before automated enumeration begins.
- Public archives and repositories may retain information that is no longer visible on a live website.
- Gobuster modes have different purposes: dir for paths, dns for subdomains, and vhost for HTTP virtual hosts.
- Wordlist choice and response filtering affect the quality of enumeration results.
- Discovered content is a starting point for further authorized testing, not proof of a vulnerability by itself.